

GRC102 Week 3 Practical Laboratory

Roles Responsibilities and Accountability in Security Governance

TechGlobal Governance Transformation Consultant Report

Student information	Details
Student name	Adediran Eunice Adebukola
Registration number	C11-26-CGRCE-17595
Course	GRC102 Information Security Governance
Submission date	25 September 2026
Submission	Consultant report with six evidence bundles

Prepared for the Board and executive management of TechGlobal. The report replaces informal IT-centred decision-making with a defined governance structure, clear authority, formal committees, measurable accountability and an auditable escalation process.

Executive summary

TechGlobal has outgrown its informal security governance model. A single IT Director currently acts as security owner, operational decision-maker and risk approver, while business units make inconsistent local choices and the Board receives limited information. This concentration creates unclear accountability, weak challenge, uneven control implementation and delayed escalation.

The recommended model places the Board in an oversight role, the CEO as the senior executive accountable for implementation, and a CISO with direct access to the Board and administrative reporting to the CEO. The CRO integrates cyber risk into enterprise risk, while Legal, Finance and HR retain authority for their specialist decisions. IT and Business Units remain first-line owners of technology and operational risk. An Executive Security Council handles strategic decisions, a monthly Security Governance Committee resolves cross-functional matters, and an Incident Response and Resilience Working Group manages detailed operational coordination.

The model is designed for a 2,500-person organisation across five offices. It avoids creating five separate security silos by using business representatives, common policies, shared metrics and central escalation thresholds. Fifteen RACI activities have one accountable owner each. Material risks move through Operational, Executive and Board levels according to defined impact and authority thresholds, and every significant decision is recorded with its owner, rationale, actions, review date and closure evidence.

Contents and evidence bundles

- Evidence Bundle 1 Governance architecture and stakeholder analysis
- Evidence Bundle 2 Governance responsibilities and authority
- Evidence Bundle 3 Committee and decision governance
- Evidence Bundle 4 RACI and implementation guide
- Evidence Bundle 5 Cyber risk escalation
- Evidence Bundle 6 Segregation of duties and assurance
- References

Evidence Bundle 1 Governance Architecture and Stakeholder Analysis

1.1 Governance gap assessment

Current weakness	Business or risk consequence	Priority response
The IT Director acts as security owner, operational manager and risk approver.	There is no independent challenge; delivery pressure may influence risk acceptance and reporting.	Appoint a CISO, separate risk approval from control operation and give the Board an escalation route.
No formal governance committees exist.	Cross-functional decisions depend on personal relationships and may not include Legal, Risk, Finance, HR or Business Units.	Create an Executive Security Council, Security Governance Committee and specialist working group.
Business units make inconsistent local security choices.	Controls, risk treatment and customer commitments vary across offices, creating avoidable exposure.	Use common policy, delegated authority limits and named Business Unit risk owners.
The CEO and Board receive limited cyber-risk visibility.	Material risks may remain below the level authorised to accept them; investment decisions lack evidence.	Introduce quarterly Board reporting and immediate material-event notification.
There is no reliable escalation path.	Incidents and exceptions may be delayed, informally accepted or closed without a decision trail.	Adopt three escalation levels with triggers, response times and acceptance authority.
Security accountability is not measured.	Overdue remediation and repeated control failures can persist without executive attention.	Assign KPIs to each role and report trends, exceptions and action age.
No independent assurance relationship is defined.	Management may confirm the effectiveness of controls it designed or operates.	Internal Audit should report functionally to the Board and independently test high-risk controls.

The current condition resembles the “Partial” end of the NIST Cybersecurity Framework maturity spectrum: decisions are ad hoc, accountability is concentrated and enterprise visibility is limited. NIST CSF 2.0 places roles, responsibilities, policy and oversight within the Govern function and expects cybersecurity to connect with enterprise risk management (NIST, 2024).

1.2 Stakeholder map

Stakeholder	Authority and influence	Primary interest	Information needed	Expected contribution
Board	Highest oversight authority; sets risk appetite and delegates executive authority.	Material risk, resilience, regulatory exposure and assurance.	Quarterly risk profile, material incidents, exceptions above appetite, remediation and assurance.	Approve direction and appetite; challenge management; decide material risk acceptance.
CEO	Enterprise executive authority and resource allocation.	Growth, reliable operations, trust and accountable execution.	Strategic exposure, options, cost, business impact and unresolved cross-functional issues.	Chair Executive Security Council; resolve conflict; sponsor resources and culture.
CISO	Security policy, strategy, monitoring, challenge and escalation authority.	Effective controls, timely risk decisions and consistent security practice.	Threats, control performance, incidents, exceptions, supplier risks and business plans.	Lead governance design, advise decision-makers, report independently and coordinate response.
CRO or Risk	Enterprise risk method, aggregation and monitoring authority.	Comparable risk ratings, tolerance and treatment.	Cyber risks, dependencies, financial and operational impact, accepted exceptions.	Challenge assessments, integrate the enterprise register and monitor accepted risks.
Legal and Compliance	Authority over legal interpretation, privilege and regulatory notification advice.	Legal duties, privacy, contracts and defensible evidence.	Affected data, jurisdictions, timing, facts, communications and contractual terms.	Advise notification decisions, preserve legal evidence and track deadlines.

Stakeholder	Authority and influence	Primary interest	Information needed	Expected contribution
Finance	Budget, financial-control and investment governance.	Loss exposure, affordability, fraud prevention and value from investment.	Cost scenarios, expected loss, budget use, insurance and control benefits.	Prioritise funding, validate financial impact and protect payment controls.
Human Resources	Workforce lifecycle, conduct and disciplinary authority.	Trusted workforce, fair processes and timely access changes.	Insider risk, access exceptions, training completion and investigation needs.	Operate joiner mover leaver controls, awareness and disciplinary processes.
IT and Technology	Operational authority for systems, services and technical remediation.	Secure delivery, availability, supportability and recovery.	Standards, vulnerabilities, architecture decisions, incidents and recovery priorities.	Implement controls, produce evidence, recover services and escalate residual risk.
Business Unit Leaders	First-line ownership of process and local operational risk.	Customer delivery, performance, usable controls and accepted residual risk.	Relevant risk, service dependency, policy changes, incidents and treatment options.	Own business controls, fund local treatment and provide impact information.

1.3 Security governance organisation chart

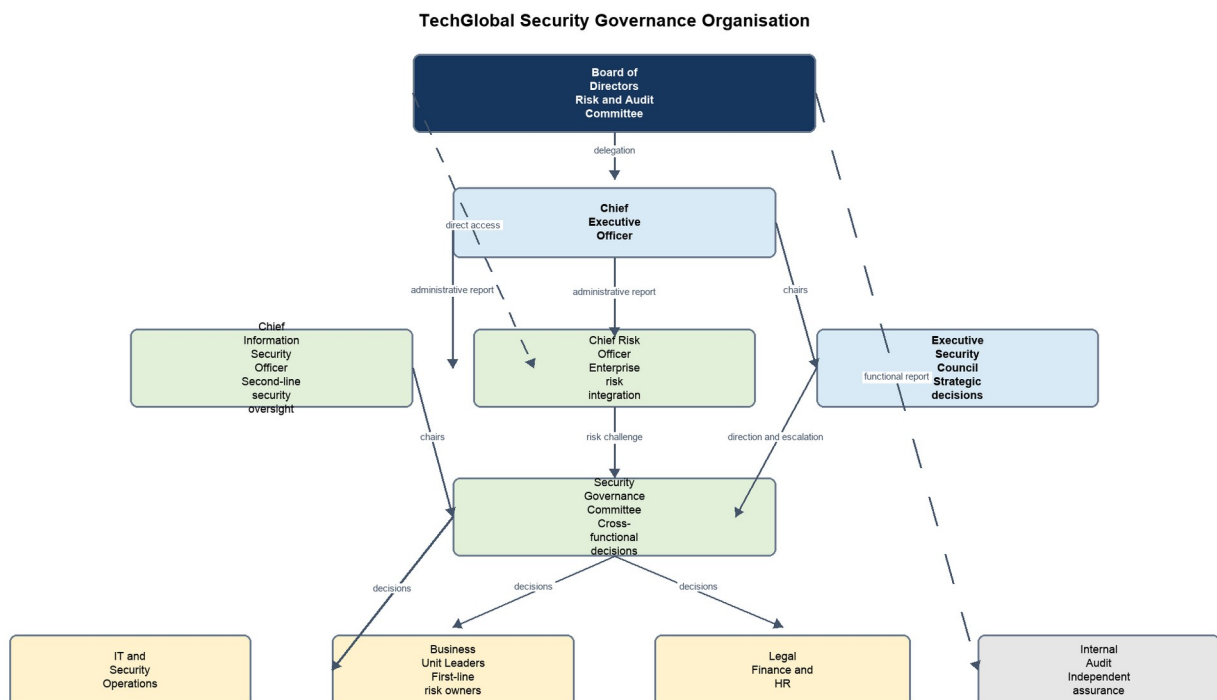


Figure 1 TechGlobal security governance organisation

1.4 Consultant justification

TechGlobal needs governance that scales across offices without turning security into a remote central function. The proposed structure achieves this by centralising standards, oversight and risk aggregation while leaving control operation and day-to-day risk management with IT and the Business Units. This follows the Three Lines principle that management remains responsible for managing risk, while specialist second-line functions provide support, monitoring and challenge and Internal Audit provides independent assurance (IIA, 2020).

The CISO reports administratively to the CEO because security affects strategy, products, customers and legal obligations, not only technology. Direct access to the Board protects the CISO's ability to report material disagreement

or unresolved exposure. The CRO does not replace the CISO: Risk owns the common enterprise method and aggregation, while the CISO supplies cyber expertise and programme oversight. The CIO or IT Director remains accountable for secure technology delivery and remediation.

The committee layers are deliberately limited. The Executive Security Council decides priorities, funding and high-impact risk. The Security Governance Committee handles recurring cross-functional decisions. The Incident Response and Resilience Working Group prepares operational matters and coordinates during events. Business Units participate through named representatives and risk ownership, which provides local knowledge without creating independent security rules. Standard templates, thresholds and metrics allow all five offices to use the same governance language.

The design is proportionate for 2,500 employees. It does not require every issue to reach executives. Routine matters stay at Level 1; only exposure beyond delegation or tolerance moves upward. This preserves speed while ensuring that the person accepting risk has the authority and information to do so. The Board receives concise trend and exception reporting plus immediate notification of material events. The expected result is faster decisions, clearer ownership, consistent controls and an auditable record.

Evidence Bundle 2 Governance Responsibilities and Authority

2.1 Cross functional governance responsibility matrix

Role	Purpose	Core governance responsibilities	Decision authority	Reports or escalates to	KPIs and evidence
Board	Provide oversight and protect stakeholder interests.	Set risk appetite; approve security direction; challenge management; oversee assurance and material remediation.	Accept risk above appetite or executive delegation; direct independent review.	Shareholders and stakeholders.	Quarterly reporting on time; material actions closed; overdue high risks; assurance coverage.
CEO	Ensure strategy is executed and adequately resourced.	Resolve cross-functional conflict; sponsor culture; chair Executive Security Council; ensure Board decisions are implemented.	Approve enterprise priorities, budget proposal and risk within delegation.	Board.	Executive actions closed on time; residual risks within appetite; funded priority treatments.
CISO	Lead security governance and provide informed challenge.	Strategy, policy, risk oversight, metrics, incident governance, architecture requirements and Board reporting.	Approve security standards and temporary containment; recommend risk treatment and escalation.	CEO; direct access to Board.	Critical remediation age; incident containment time; control coverage; exceptions overdue.
CRO or Risk	Integrate cyber risk into enterprise risk management.	Maintain method, appetite measures, aggregation, challenge, acceptance register and monitoring.	Validate risk ratings; approve method; escalate exposure beyond tolerance.	CEO and Board Risk Committee.	Risks reviewed on schedule; acceptance expiry compliance; risk-data quality; overdue treatments.
Legal	Give legal, privacy and compliance advice.	Interpret duties and contracts; preserve privilege; guide notification; retain defensible decision records.	Own legal conclusions and notification recommendation; approve external legal wording.	General Counsel, CEO and Board where material.	Legal assessment within target; notification deadlines met; contractual obligations tracked.
Finance	Govern investment and financial exposure.	Budget challenge, loss estimation, insurance, payment controls and emergency funding.	Approve spending within delegation; validate financial materiality.	CFO and CEO.	Budget variance; priority funding coverage; fraud-control exceptions; loss estimates completed.
HR	Govern workforce security.	Screening, joiner mover leaver, awareness, conduct, investigations and discipline.	Approve workforce actions and disciplinary outcomes with Legal advice.	Chief People Officer and CEO.	Access removal timeliness; training completion; repeat policy breaches; screening completion.
IT	Deliver secure and resilient technology.	Implement controls, patching, logging, backup, recovery, asset management and operational evidence.	Approve operational changes within standards; cannot accept residual enterprise risk.	CIO or IT Director; escalates risk to CISO.	Critical patch compliance; recovery-test success; unsupported assets; change success rate.

2.2 Responsibility cards

Board

Purpose. Maintain oversight rather than operate controls. Ask whether material exposure is understood, within appetite and independently assured.

Authority. Risk appetite; material acceptance; direction to management.

Reporting evidence. Quarterly dashboard, private CISO and Internal Audit sessions, material-event briefing.

Performance indicators. 100% scheduled reports received; no overdue Board-owned actions.

CEO

Purpose. Turn Board direction into enterprise action and ensure security supports business objectives.

Authority. Executive prioritisation, resources and cross-functional resolution.

Reporting evidence. Executive Security Council minutes, funding decisions and risk acceptance records.

Performance indicators. At least 90% executive actions on time; all above-delegation risks escalated.

CISO

Purpose. Set the security direction, challenge control owners and provide reliable reporting.

Authority. Security standards, governance proposals, containment authority and escalation.

Reporting evidence. Risk dashboard, exception register, incident review and annual strategy.

Performance indicators. Critical exceptions within target; material incidents escalated within four hours.

CRO or Risk

Purpose. Apply a consistent enterprise method and prevent cyber risk from being isolated.

Authority. Risk method, validation, aggregation and monitoring.

Reporting evidence. Enterprise risk register, acceptance expiry report and scenario analysis.

Performance indicators. 100% material risks have owners; expired acceptances equal zero.

Legal

Purpose. Protect TechGlobal by giving timely, documented legal and compliance advice.

Authority. Legal interpretation, privilege, notification advice and approved legal language.

Reporting evidence. Legal assessment record, jurisdiction checklist and notification timetable.

Performance indicators. 100% Level 2 and 3 events assessed within target; no missed legal deadline.

Finance

Purpose. Link security choices to financial exposure and disciplined investment.

Authority. Budget approvals within delegation, financial materiality and payment controls.

Reporting evidence. Investment cases, loss estimates, insurance claims and budget reports.

Performance indicators. Priority controls funded; emergency loss estimate within 24 hours.

Human Resources

Purpose. Make workforce security reliable and fair across the employee lifecycle.

Authority. Workforce processes, awareness and discipline with Legal consultation.

Reporting evidence. Employment status feed, training report, case record and access reconciliation.

Performance indicators. Access removed within four hours of high-risk termination; training above 98%.

IT

Purpose. Operate secure services and produce evidence that technical controls work.

Authority. Technical changes within standards and emergency containment with incident authority.

Reporting evidence. Patch reports, logs, recovery tests, asset register and remediation tickets.

Performance indicators. Critical patches within policy; recovery objectives met in tests.

2.3 Authority conflicts and resolution principles

Potential overlap	Risk	Resolution
CISO security approval and IT delivery authority	IT may approve its own exception or the CISO may take over operational management.	CISO sets requirements and challenges; IT implements. Residual risk is accepted by the authorised business or executive owner.
CISO cyber assessment and CRO enterprise risk method	Duplicate registers or competing ratings can obscure exposure.	CRO owns the common method and aggregation; CISO owns cyber analysis. One enterprise register is used.
Legal notification advice and CEO business decision	Commercial pressure may delay notification or Legal may be expected to make operational choices.	Legal owns the legal opinion and deadline; CEO authorises the corporate action unless law assigns the duty elsewhere. Dissent is recorded.
Finance budget control and CISO risk prioritisation	High-risk treatment may be deferred solely for cost.	CISO states risk reduction and urgency; Finance validates cost; CEO prioritises within appetite; Board decides unresolved material exposure.

Resolution principles. Separate control operation from risk acceptance; assign one accountable decision owner; use written delegation limits; record dissent and rationale; escalate when authority, risk appetite or legal duties are exceeded; and preserve Internal Audit independence.

Evidence Bundle 3 Committee and Decision Governance

3.1 Committee ecosystem

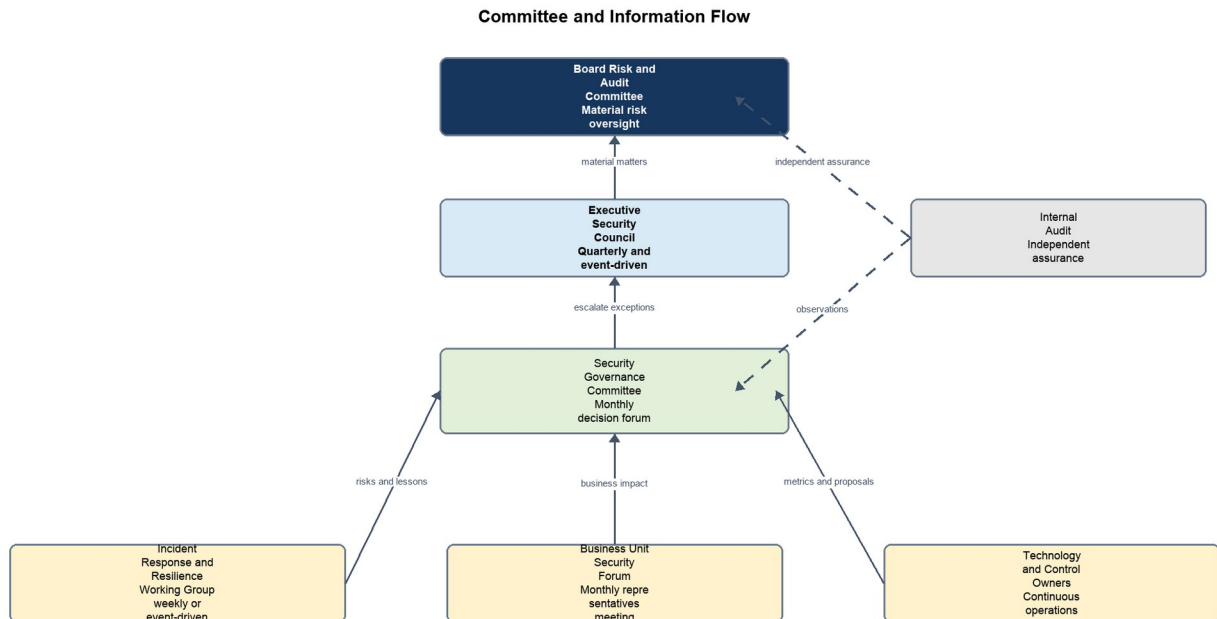


Figure 2 TechGlobal committee and information flow

Forum	Purpose and membership	Cadence	Decision scope and escalation
Board Risk and Audit Committee	Board oversight; CISO, CRO and Internal Audit attend as required.	Quarterly and event-driven.	Risk appetite, material acceptance, assurance, significant incidents and overdue remediation.
Executive Security Council	CEO chair; CISO, CRO, CIO, General Counsel, CFO, HR and major business executives.	Quarterly and within four hours of a material trigger.	Strategy, investment, Level 2 acceptance, crisis direction and recommendations to the Board.
Security Governance Committee	CISO chair; Risk, Legal, Finance, HR, IT, Privacy, Internal Audit observer and Business Unit representatives.	Monthly.	Policies, metrics, exceptions, priorities, supplier risk and Level 1 or delegated Level 2 decisions.
Incident Response and Resilience Working Group	Incident lead; SOC, IT, Legal, Privacy, Risk, Communications, HR, Finance and affected Business Unit.	Weekly readiness; event-driven during incidents.	Operational playbooks, exercises, incident coordination, lessons and proposals to the committee.
Business Unit Security Forum	Business risk owners and local security coordinators.	Monthly before the Governance Committee.	Local risks, control adoption, customer commitments and impact information; no separate standards.

3.2 Security Governance Committee terms of reference

Element	Terms
Mandate	Provide the cross-functional management forum for cybersecurity policy, risk, compliance, investment and performance decisions within delegated authority.
Chair and secretariat	CISO chairs. GRC Manager acts as secretary and maintains papers, attendance, decision log and action register.
Voting members	CISO, CRO delegate, Legal, Finance, HR, IT and one representative from each major Business Unit. Internal Audit attends as a non-voting observer.
Quorum	Chair or deputy plus Risk or Legal, IT and at least two Business Unit representatives. Decisions affecting Finance or HR require the relevant representative.
Authority	Approve management standards, Level 1 risk acceptance within delegation, remediation priorities and committee actions. Recommend policies, material risk, budget and strategy to higher authority.
Inputs	Risk register, incidents, vulnerabilities, supplier assessments, policy exceptions, audit findings, metrics, legal changes and business proposals.
Outputs	Approved decisions, risk recommendations, assigned actions, escalation papers, policy changes and a monthly executive summary.
Decision rule	Seek consensus. If consensus is not reached, the chair records views and escalates to the Executive Security Council. No silence-based approval.
Records	Agenda and papers issued three working days before the meeting. Minutes and decision log issued within two working days. Records retained under the corporate schedule.
Review	Effectiveness and membership reviewed annually by the Executive Security Council; Internal Audit may assess operation independently.

3.3 Sample monthly agenda

Time	Agenda item	Lead	Expected output
09:00	Opening, conflicts and previous minutes	Chair	Quorum and approved record
09:10	Actions and overdue decisions	Secretary	Updated owners and dates
09:25	Risk profile and appetite exceptions	CRO and CISO	Acceptance, treatment or escalation
09:50	Incidents and resilience	Incident Lead	Lessons and corrective actions
10:10	Legal, privacy and regulatory update	Legal	Required policy or control change
10:25	Control performance and vulnerabilities	IT and CISO	Prioritised remediation
10:45	Third-party and business-unit	Procurement and BU reps	Supplier or business decision

Time	Agenda item	Lead	Expected output
	matters		
11:05	Policies, investment and change proposals	Relevant sponsor	Approval or recommendation
11:25	Decisions, escalations and close	Chair	Confirmed decision log

3.4 Sample decision log

Date	Decision or issue	Owner	Decision and rationale	Actions and owner	Review
15 Oct 2026	Legacy remote access lacks MFA	CISO	Disable external access unless MFA is enabled by 31 Oct. Exposure exceeds the technical exception limit.	IT enables MFA; BU validates users; CISO verifies.	5 Nov 2026
12 Nov 2026	Critical supplier will not provide current test evidence	CEO	Continue for 60 days with restricted integration while procurement completes alternate-provider assessment.	Procurement and CISO complete exit option; Legal amends terms.	10 Jan 2027
14 Jan 2027	Critical patching below target in Office 4	CIO	Approve two-week recovery sprint and weekly reporting; no risk acceptance beyond 31 Jan.	IT Director assigns team; BU freezes nonessential change.	1 Feb 2027

3.5 Twelve month governance calendar

Month	Recurring activities and milestones
October 2026	Launch governance model; approve charters; appoint BU representatives; baseline risk and action registers.
November 2026	Approve security policy framework; review critical suppliers; establish Board dashboard.
December 2026	Quarterly Executive Council; annual budget prioritisation; holiday readiness and on-call review.
January 2027	Board quarterly report; access recertification; critical asset and owner confirmation.
February 2027	Cloud and architecture review; incident-response tabletop; close exercise actions.
March 2027	Quarterly Executive Council; privacy and contractual obligations review; supplier concentration assessment.
April 2027	Board quarterly report; business-continuity and recovery exercise; policy exception review.
May 2027	Awareness effectiveness review; phishing trend and disciplinary-process check; HR-IAM reconciliation.
June 2027	Quarterly Executive Council; mid-year risk appetite assessment;

Month	Recurring activities and milestones
	investment re-prioritisation.
July 2027	Board quarterly report; privileged-access recertification; penetration-test remediation review.
August 2027	Third-party assurance cycle; critical supplier exercise; next-year strategy proposals.
September 2027	Annual governance effectiveness review; policy review; independent assurance summary; next 12-month plan.

Every month: Security Governance Committee, Business Unit Security Forum, risk and exception review, metrics update and decision-log follow-up. Every quarter: Executive Security Council and Board reporting. Event-driven meetings occur whenever an escalation threshold is met.

Evidence Bundle 4 RACI and Implementation Guide

R means Responsible, A Accountable, C Consulted and I Informed. One accountable role is assigned to every activity. The Board column represents the authorised Board committee.

Activity	Board	CEO	CISO	Risk	Legal	Finance	HR	IT	BU
Cybersecurity strategy approval	A	R	R	C	C	C	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	C	R	A	C	C	C	R	R
Risk acceptance	A	R	C	C	C	C	I	I	R
Security budget approval	I	A	R	C	C	R	I	C	C
Security architecture approval	I	I	A	C	C	I	I	R	C
Third-party security review	I	I	A	C	C	C	I	R	C
Access governance	I	I	A	C	C	I	R	R	C
Incident response governance	I	A	R	C	C	C	C	R	R
Material incident escalation	I	A	R	C	C	C	C	R	C
Regulatory notification decision	I	I	C	C	A/R	I	I	C	I
Security awareness programme	I	I	R	C	C	I	A	C	C
Vulnerability remediation oversight	I	I	A	C	I	I	I	R	R
Business continuity and recovery governance	I	A	C	C	C	C	C	R	R
Board cyber-risk reporting	I	C	A/R	C	C	C	I	C	C

4.1 Problematic assignments to avoid

Problematic assignment	Why it fails	Correct treatment
Making IT accountable for risk acceptance	IT would approve exposure created by its own delivery choices and may lack authority over business consequences.	Business owner accepts within delegation; CEO or Board accepts higher exposure. IT is responsible for treatment.
Making the Board responsible for incident response	The Board cannot operate a time-sensitive response and would blur oversight with management.	CEO is accountable for governance; CISO and IT are responsible; Board receives material escalation.
Making the CISO accountable for disciplinary action	The CISO supplies evidence but should not decide employment outcomes or bypass fair process.	HR is accountable, Legal is consulted and management provides facts.
Assigning two accountable roles to regulatory notification	Competing authority can delay a time-bound legal decision.	Legal is accountable for the legal notification decision; CEO is informed and directs corporate response.

4.2 Manager implementation guide

Use the RACI at the start of an activity, not after disagreement occurs. The accountable person confirms the scope, decision deadline and evidence required. Responsible roles perform the work. Consulted roles are engaged early enough to influence the outcome, while informed roles receive the final decision or status.

1. Planning: identify the activity row, confirm that the accountable owner has the required delegation, list responsible deliverables and schedule consultation.
2. Approval: the accountable role reviews evidence, records the decision and conditions, and does not treat meeting attendance as approval.
3. Incidents: the RACI does not replace the incident plan. Operational responders act immediately within authority, then use the escalation thresholds to reach the correct accountable decision-maker.
4. Absence: each accountable executive appoints a named deputy with written delegation. Accountability is not shared between the owner and deputy at the same time.
5. Disagreement: document the positions and escalate one level. The CISO and Legal may record formal dissent where risk or legal duties remain unresolved.
6. Maintenance: the GRC Manager reviews the matrix after reorganisations, major incidents and annually. Changes require Security Governance Committee recommendation and CEO approval.

Managers should test the matrix during tabletop exercises. Evidence of use includes approval records, meeting minutes, incident timelines, risk acceptances and action closure. A useful RACI reduces delay; it should be corrected if it creates unnecessary consultation or leaves a decision without authority.

Evidence Bundle 5 Cyber Risk Escalation

5.1 Major cyber risk escalation workflow

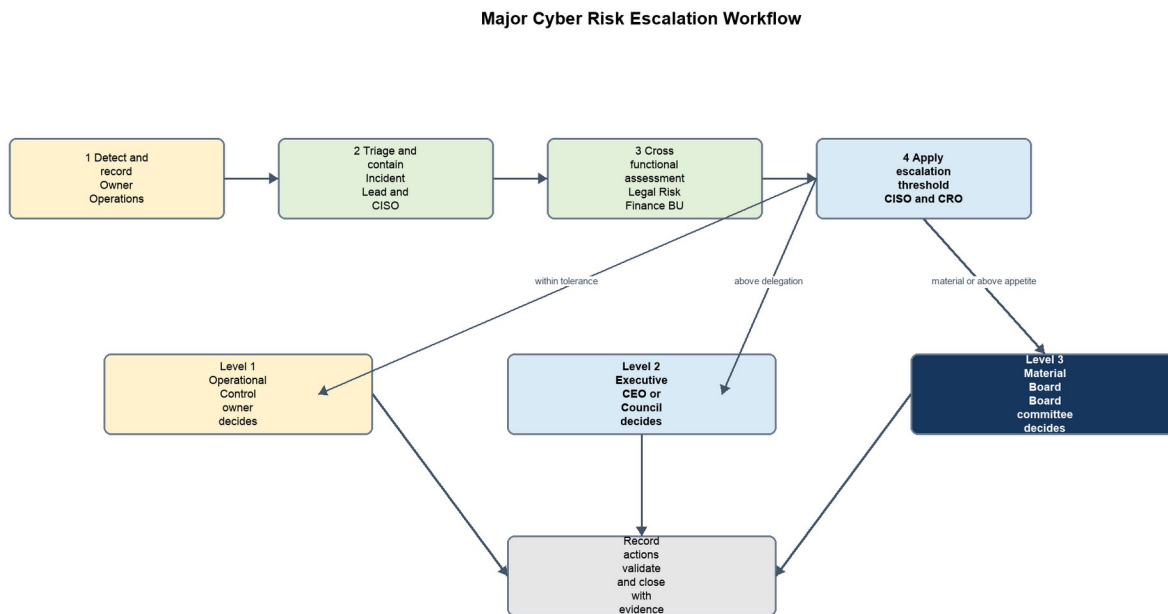


Figure 3 Major cyber risk escalation workflow

7. Detect and record. Operations, a Business Unit, supplier or assurance provider creates a risk or incident record with time, source, affected service and available evidence.
8. Triage and contain. The incident lead and IT take authorised containment action. The CISO validates severity and ensures evidence is preserved.
9. Assess across functions. Legal considers notification and privilege; Risk considers appetite and aggregation; Finance estimates loss; the Business Unit states customer and service impact; HR joins where people are involved.
10. Apply thresholds. The CISO and CRO compare credible impact, uncertainty, control weakness and authority with the escalation table. When uncertain between levels, use the higher level until facts improve.
11. Decide. The control or business owner decides Level 1 matters. The CEO or Executive Security Council decides Level 2. The Board committee decides material acceptance or exposure above appetite.
12. Record and track. The secretary records the decision, conditions, owner, due date, review date and dissent. Risk tracks acceptance expiry and action age.
13. Validate and close. CISO verifies security treatment, the Business Unit confirms operational completion, Risk confirms residual exposure, and Internal Audit may independently validate material closure.

5.2 Escalation threshold table

Level	Example triggers	Decision authority	Required notification	Target response
Level 1 Operational	Contained incident; no regulated data; limited users; expected loss within local limit; risk within tolerance.	System or Business Unit owner within written delegation.	CISO operational team and relevant manager.	Triage within 4 hours; decision within 2 business days.
Level 2 Executive	High severity; important-service outage; confirmed sensitive data; significant	CEO or Executive Security Council.	CISO, CRO, Legal, Finance, affected BU and CEO.	Initial notice within 1 hour for incident or 1 business day for risk; decision within 24 hours.

Level	Example triggers	Decision authority	Required notification	Target response
	supplier issue; repeated control failure; likely loss above local limit; risk near or above tolerance.			
Level 3 Material or Board	Material customer or financial effect; widespread regulated-data exposure; critical-service outage beyond tolerance; ransomware; public disclosure likely; risk above appetite; executive conflict unresolved.	Board Risk and Audit Committee; emergency authority may be exercised under Board delegation.	Board Chair or committee, CEO, CISO, CRO, Legal and relevant executives.	Executive notice immediately; Board notice within 4 hours; decision cadence set by incident commander.

Trigger measurements must be set through TechGlobal's approved risk appetite and financial delegations. The examples above define the governance route; they do not invent a monetary materiality threshold that the scenario does not provide.

5.3 Decision recording and assurance

The GRC system holds a single decision record linked to the incident, risk, exception, supplier or audit finding. Required fields are decision ID, date, facts known, uncertainty, impact, threshold, options, legal advice reference, risk owner, decision authority, rationale, conditions, actions, due dates, review date, residual rating and closure evidence. The secretary issues minutes within two working days; urgent verbal decisions are documented before the end of the operational shift where practicable.

Open actions are reviewed monthly. Risk flags expired acceptance and overdue Level 2 or 3 treatment to the Executive Security Council. The CISO validates technical completion; control owners provide evidence; Internal Audit selects material decisions for independent review. Records are protected against unauthorised change and retained under Legal's approved schedule.

Evidence Bundle 6 Segregation of Duties and Assurance

6.1 Segregation of duties and accountability weakness register

ID	Weakness or conflict	Risk created	Roles involved	Recommended control	Residual risk and review
SOD-01	IT Director owns security, operates controls and accepts risk.	Self-approval, incomplete challenge and concealed delivery pressure.	IT, CISO, CEO, Risk.	Separate CISO and IT roles; business or executive owner accepts risk; Risk monitors expiry.	Medium; quarterly acceptance review.
SOD-02	Developer can deploy code and approve emergency change.	Unauthorised or untested code may enter production without independent review.	Development, IT Operations, Product.	Peer approval, protected pipeline, logged emergency approval and next-day review.	Low to Medium; monthly exception sample.
SOD-03	Administrator requests and approves privileged access.	Excess privilege may be granted and remain undetected.	IT, IAM, manager, system owner.	Manager and system-owner approval; PAM vault; quarterly recertification; session logging.	Medium; quarterly privileged review.
SOD-04	HR termination notice and access removal rely on informal email.	Departed personnel may retain access or evidence may be incomplete.	HR, IAM, manager, IT.	HR system trigger, four-hour high-risk removal target and daily HR-directory reconciliation.	Low; monthly reconciliation evidence.
SOD-05	Finance initiates, approves and reconciles security emergency payments.	Fraud or error may be concealed during a crisis.	Finance, Incident Lead, CEO.	Separate requester, approver and reconciler; emergency limit; post-event Finance and Audit review.	Medium; review every emergency payment.
SOD-06	CISO operates controls and reports their effectiveness without independent assurance.	Board may receive management assertion instead of objective assurance.	CISO, Internal Audit, Board.	Internal Audit independently tests material controls and reports functionally to the Board.	Low to Medium; annual assurance plan.
SOD-07	Business Unit can contract a supplier and accept its cyber risk.	Commercial deadlines may override due diligence or contractual safeguards.	BU, Procurement, CISO, Legal, Risk.	Tiered review; Legal security clauses; risk acceptance outside the buying chain; executive approval for critical exceptions.	Medium; quarterly critical-supplier review.

6.2 Assurance note

The governance model uses management evidence and independent assurance for different purposes. IT and Business Units attest that controls are operated and provide logs, tickets and test results. The CISO and Risk perform second-line monitoring and challenge. Internal Audit remains independent of management decisions and reports to the Board on whether governance, risk management and controls are designed and operating effectively. This separation follows the IIA Three Lines Model and prevents the CISO from auditing a programme the CISO manages.

Assurance should be risk-based. Priority topics for the first year are privileged access, remote access, incident escalation, critical supplier governance, recovery testing and closure of material actions. Committee self-assessment, decision-log sampling, overdue-action trends and direct interviews with Business Units should be included. Findings are assigned to management; Internal Audit does not own remediation.

Implementation roadmap

Period	Key actions	Owner	Evidence of completion
First 30 days	Board approves target model; CEO appoints CISO or interim lead; charters and delegation drafted; material risks identified.	Board and CEO.	Approved model, appointments, charters and initial risk list.
Days 31 to 90	Launch committees; nominate BU representatives; approve RACI and escalation process; begin dashboards and decision log.	CISO and CRO.	Meeting records, trained role owners, dashboard and populated registers.
Months 4 to 6	Approve policy framework; exercise incident and escalation workflow; review critical suppliers and privileged access.	Security Governance Committee.	Policies, exercise report, supplier decisions and access review.
Months 7 to 12	Operate calendar; refine metrics; complete independent assurance; review effectiveness and next-year plan.	Executive Council and Internal Audit.	Quarterly reports, assurance opinion, closure evidence and approved improvement plan.

Conclusion

TechGlobal's central problem is not the absence of technical activity; it is the absence of clear governance. The proposed model distributes authority to the right level, preserves business ownership, gives the CISO enough independence to challenge, connects cyber risk to enterprise risk and provides the Board with reliable oversight. The committee ecosystem, RACI, escalation thresholds and decision records are designed to work together. Implemented in the staged roadmap above, they will replace informal decisions with consistent, timely and auditable accountability across all five offices.

References

- International Organization for Standardization (ISO) (2022).** ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection Information security management systems Requirements. Geneva: ISO.
<https://www.iso.org/standard/27001.html>
- National Institute of Standards and Technology (NIST) (2024).** The NIST Cybersecurity Framework 2.0. NIST CSWP 29.
<https://doi.org/10.6028/NIST.CSWP.29>
- The Institute of Internal Auditors (IIA) (2020).** The IIA Three Lines Model.
<https://www.theiia.org/globalassets/site/about-us/advocacy/three-lines-model-updated.pdf>
- International Cybersecurity and Digital Forensics Academy (2026).** GRC102 Week 3 Practical Laboratory Roles Responsibilities and Accountability in Security Governance. Course brief.